Análise de arquivo suspeito

Share

exec.x

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando as regras de análise de malware para este arquivo

Vou começar lendo as instruções da skill de leitura de arquivos e, em seguida, farei uma análise estática do arquivo, sem executá-lo.

Read a file, ran a command

É um executável ELF de 64 bits para Linux, pequeno (~16 KB) e *stripped* (sem símbolos). Vou continuar a análise estática: cabeçalhos, bibliotecas e funções importadas, seções e entropia.

Ran 9 commands, searched the web

Analisei o arquivo de forma 100% estática, sem executá-lo em nenhum momento.

1. **Identificação.** Apesar da extensão `.x`, é um executável ELF de 64 bits para Linux x86-64, de 16.688 bytes, sem símbolos e compilado com o GCC 14.2.0 do Debian 13. SHA-256: `d166fe35d07e1303ee8f1b082a0c3d50b66eead61e30ef40753dd6e1fef56a30`.
2. **Estrutura.** O layout é o normal do GCC. Não há *packer* (UPX etc.), segmento gravável e executável ao mesmo tempo, nem dados anexados ao fim do arquivo. A pilha não é executável e só existem os construtores e destrutores padrão.
3. **Importações.** Usa apenas a `libc`: `getenv` / `putenv`, `stat`, `time` / `atoll`, `memcmp` e `execvp`. Não importa nenhuma função de rede, nem `fork`, `ptrace`, `mmap` / `dlopen`, `system` / `popen` ou `setuid`. Também não abre, grava ou apaga arquivos, só imprime erros no `stderr`.
4. **Strings e entropia.** As poucas strings legíveis (`x%lx`, `=%lu %d`, `E: neither argv[0] nor $_ works.`) são a assinatura do **shc** (*Shell Script Compiler*). A seção `.data` tem entropia de 7,87 de 8 possíveis, ou seja, é um script cifrado.
5. **Lógica do código.** Desmontei todas as funções. É o runtime padrão do shc, sem modificações. Ele decifra com RC4 um script de cerca de 1,3 KB guardado no próprio binário e o executa com `/bin/sh -c`.
6. **Configuração.** Reproduzi a decifragem dos metadados e o teste de integridade interno passou. Tudo está no padrão da ferramenta: sem data de expiração, `/bin/sh -c`, mensagens-padrão e nenhuma opção personalizada.
7. **O ponto decisivo.** O "modo relaxado" está desligado. Por isso, a chave do script depende do inode, device, tamanho e datas do `/bin/sh` da máquina onde o arquivo

foi compilado. Testei com o `/bin/sh` deste ambiente e não bate, como esperado, já que aqui é Ubuntu e o build foi em Debian 13. **Não consegui ler o script.** Em qualquer outra máquina, o teste de integridade falha e o binário aborta sem executá-lo.

8. **Reputação.** Busquei o hash e não encontrei nenhum relatório público. Isso não prova nada, só indica que não é uma amostra conhecida.

Veredito: inconclusivo. Não encontrei nenhum indicador de malware, mas também não posso atestar que o arquivo seja benigno.

O executável em si é legítimo e inofensivo: é o shc sem alterações, sem rede, persistência ou escalonamento de privilégios. Todo o risco está no script oculto, que roda com as permissões de quem executa e que eu não consegui ver. O shc é usado tanto para proteger scripts legítimos quanto por malware Linux para escondê-los, então a ferramenta sozinha não revela a intenção.

Como o binário está preso à máquina de build, ele seria pouco útil para distribuição em massa, e o resto da configuração é a padrão, típica de um teste ou uso pessoal. Isso é só um indício: um binário assim também pode ter sido deixado em um servidor já comprometido.

O que resolveria a dúvida é o script original (`.sh`). Se você souber quem compilou o arquivo, peça o fonte, ou me envie o `.sh` e eu o analiso. Sem ele, a análise definitiva só é possível na máquina de origem (ou num clone dela), em uma VM isolada e sem rede. Se o arquivo veio de uma fonte em que você não confia, não o execute, e consulte o hash no VirusTotal, que eu não consegui acessar daqui.

Por que você não classificou o programa como malware?

Explicando por que não rotulei a amostra como malware ▸

Porque classificar algo como malware exige evidência de comportamento malicioso, e a única parte do arquivo que consegui examinar não tem nenhuma.

O que pude ver foi o *wrapper* do shc, que é código padrão e sem alterações, sem rede, persistência, injeção de código ou escalonamento de privilégios. O que poderia ser malicioso é o script de cerca de 1,3 KB escondido dentro dele, e esse eu não consegui ler, porque a chave de decifragem depende da máquina onde o arquivo foi compilado. Então a ausência do rótulo “malware” não significa “provavelmente limpo”. Significa que não tenho como ver a parte que importa.

O fato de estar ofuscado também não bastaria. O shc é uma ferramenta legítima, usada para proteger scripts comerciais e internos, ainda que também seja abusada por malware. Rotular tudo que usa shc como malware geraria muitos falsos positivos, e eu estaria julgando pela ferramenta, não pelo comportamento.

Pelo mesmo motivo, também não o chamei de benigno. Ausência de evidência não é evidência de ausência, e um falso “benigno” é o erro mais caro, porque leva alguém a executar o arquivo.

Por isso “inconclusivo” é o resultado honesto. Na prática, eu trataria o arquivo como **não confiável até ser verificado**: a opacidade é um fator de risco, mas não é prova.

Duas coisas mudariam o veredito. Uma é ver o script: se ele baixar e executar código remoto, criar persistência ou algo parecido, é malware; se for algo inofensivo, é benigno. A outra é uma detecção confiável do hash em serviços de reputação.